

The Maintenance menu and routes are not permission-gated

The Maintenance section’s visibility is hardcoded per role and its routes open by URL for anyone, because **no permission exists to control it**. One root cause, two symptoms.

MEDIUM

Env QA · V1.36

acme.qa.egalvanic.ai

Web

ROOT CAUSE

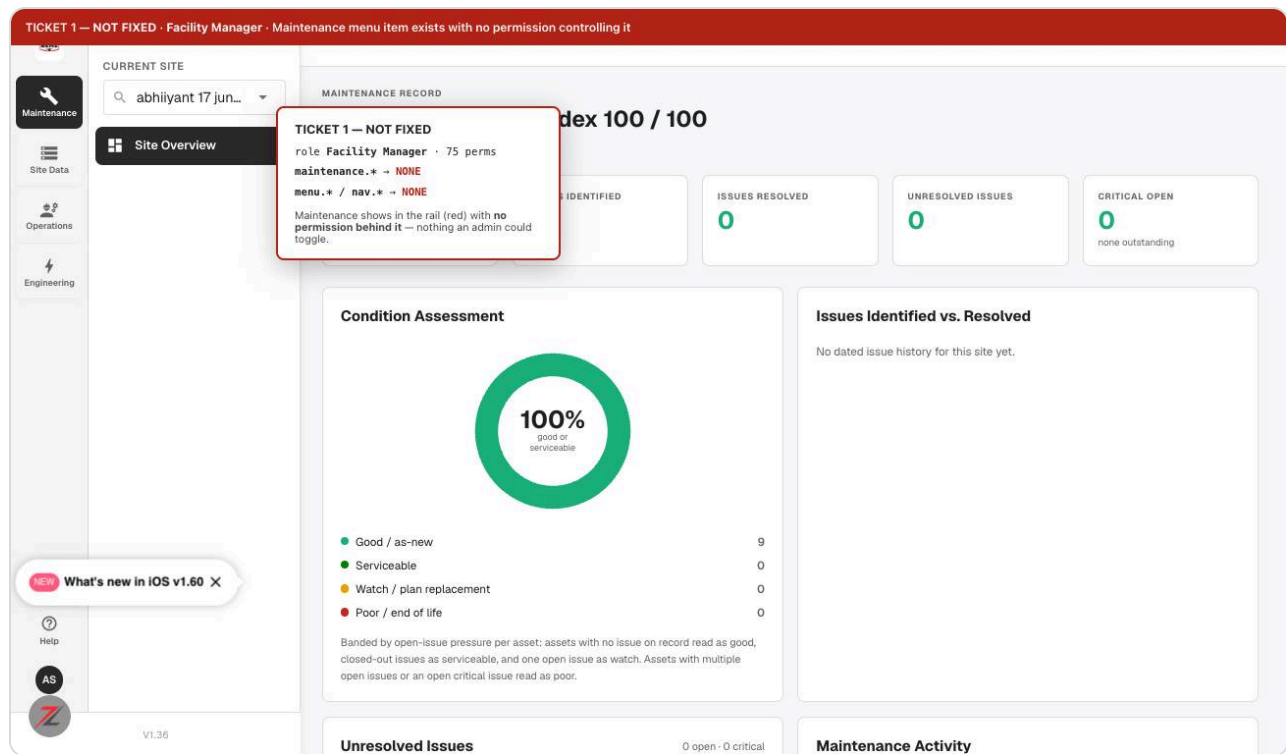
No maintenance.* permission exists for any role. Live /api/auth/v2/me, checked across Admin, Facility Manager, Client Portal and Project Manager:

```
permissions matching maintenance.* → NONE (every role)
permissions matching menu.* / nav.* → NONE (every role)
```

With no permission to check, nothing gates the Maintenance nav item or its routes. Both symptoms below follow from this.

SYMPTOM 1 · navigation

The Maintenance menu item is hardcoded, not permission-driven



The **Maintenance** rail item (red) shows for Facility Manager with no permission behind it. It appears for Client Portal + FM and is absent for Admin, PM, Account Manager and Technician — driven by hardcoded rules, not the permission matrix.

ACTUAL

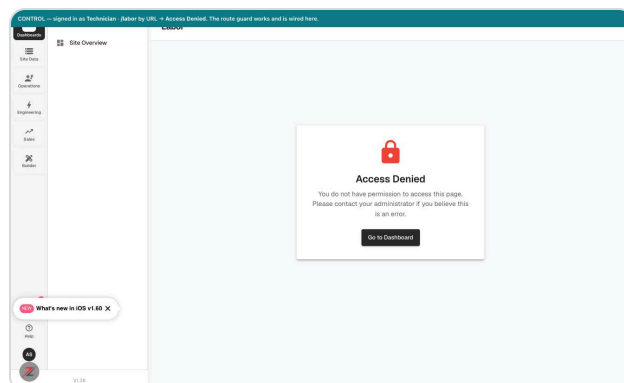
Which roles see Maintenance is fixed in code. An admin cannot show or hide it per role from the role-permission screen — it would take a code change and deploy.

EXPECTED

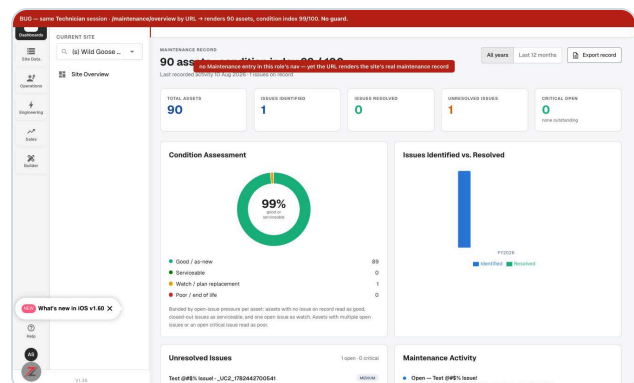
Visibility is driven by a permission an admin can toggle per role, with no deploy.

SYMPTOM 2 · routing

The routes open by direct URL for every role



Control — same Technician, /labor by URL → **Access Denied**. The route guard works and is wired on gated



Bug — same session, /maintenance/overview → renders the full record. No Maintenance entry in the rail.

routes.

by URL, roles with NO Maintenance nav entry:

Admin · Project Manager · Technician · Account Manager

/maintenance/overview → renders /maintenance/program → renders

control routes, same sessions:

/users → Access Denied /labor → Access Denied

ACTUAL

Every role, including those with no Maintenance nav entry, can type /maintenance/overview or /maintenance/program and the page renders.

EXPECTED

Roles without the Maintenance permission get **ACCESS DENIED** on these routes, exactly as they do on /users and /labor.

Severity note — not a data leak. /maintenance/overview repackages a site's assets, issues and condition — data internal roles can already reach via /assets and /issues, and for Client Portal it is their own site. So nobody sees data they otherwise couldn't. This is a **configurability / design-intent gap** (the section can't be managed from the permission matrix), not a security exposure. Sized **Medium** on that basis.

Steps to reproduce

- 1 Sign in as any role that has no Maintenance nav entry — e.g. abhiyant.singh+tec@egalvanic.com (Technician) or the Admin account.
- 2 Confirm there is no **Maintenance** item anywhere in the left rail.
- 3 In the address bar, go to /maintenance/overview (and /maintenance/program).
- 4 The page renders the full record. For contrast, try /labor — that correctly shows Access Denied.
- 5 In the console, `fetch('/api/auth/v2/me')` → no permission name contains maintenance.

Acceptance criteria for the fix

- ☐ A permission (e.g. `features.maintenance.view`) exists and gates the Maintenance nav item.
- ☐ The same permission gates /maintenance/overview and /maintenance/program at the route level — roles without it get Access Denied by URL.
- ☐ Existing access is preserved: the permission is granted to the roles that see Maintenance today (Client Portal, Facility Manager), so there is no regression.
- ☐ An admin can toggle the permission per role from the role-management screen with no code deploy.

Duplicate / link note. This is the same underlying gap as the earlier **Bug 3a** (Maintenance routes not gated) and is the concrete instance of the open ticket **“Make all menu options permission-based”**. If that ticket is being worked, this bug closes with it — link them rather than fixing twice.

Verified live on QA, 27 Aug 2026. Signed in per role through the login form, cookies and storage cleared between roles. No data created, edited or deleted.